Introduction to Cryptography

Lecture 42: Password Management, Malware, Viruses and Worms

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

Source coverage note

The supplied chapter covers password management. Malware, viruses, and worms are supplementary teaching material beyond the provided extract.

Learning objectives

- Explain password authentication and common weaknesses
- Compare password-selection strategies
- Distinguish malware, viruses and worms
- Describe safe defenses and incident response

Password authentication

- User ID identifies an account and associated privileges
- Password helps authenticate the claimant
- Authorization is distinct from authentication

Password vulnerabilities

- Weak and reused passwords
- Guessing and dictionary attacks
- Credential theft through phishing or malware
- Exposed password verifiers

Historical UNIX password scheme

- The supplied chapter describes legacy DES-based crypt(3)
- A salt modifies the password transformation
- Stored verifier is compared at login
- Historical mechanism; not a modern recommendation

Why salts matter

- Different salts yield different verifiers for the same password
- Salts frustrate precomputed lookup attacks
- A salt is public, not a secret encryption key

Modern password storage (supplement)

- Use purpose-built salted password hashing (Argon2id, scrypt or bcrypt)
- Tune work factors for the deployment
- Protect verifier databases and rate-limit login attempts

Guessing strategies

- Common passwords and dictionary words
- User-related information
- Short-password enumeration
- Offline attacks if a verifier database is stolen

Password selection: four approaches

- User education
- Computer-generated passwords
- Reactive password checking
- Proactive password checking

User education

- Explain risks of predictable and reused passwords
- Encourage long, unique passphrases
- Pair guidance with technical controls

Computer-generated passwords

- Can provide unpredictability
- May be hard to memorize
- Password managers can help users handle unique credentials

Reactive password checking

- Periodically test for weak credentials
- Weakness: vulnerable passwords remain until detected
- May be resource intensive

Proactive password checking

- Evaluate new passwords before accepting them
- Reject known weak or compromised choices
- Balance security and usability

Probabilistic password screening

- Markov models estimate guessable patterns
- Bloom filters compactly represent disallowed lists
- Bloom filters can yield false positives

Bloom filter idea

- Set several bit positions for each forbidden word
- Test all corresponding bits for a proposed password
- If all are set, it may be in the set
- False positives are possible

Password protection checklist (supplement)

- Multi-factor authentication
- Rate limiting and monitoring
- Unique passwords and password managers
- Timely account deprovisioning

Malware definition (supplement)

- Software designed to harm, disrupt, spy or gain unauthorized access
- Malware is a broad category
- Viruses and worms are particular forms

Malware categories (supplement)

- Trojan: malicious functionality disguised as benign software
- Ransomware: attempts to deny access and demand payment
- Spyware: covertly collects information
- Rootkit: attempts to conceal unauthorized activity

Computer virus (supplement)

- Replicates by infecting a host file or program
- Often needs execution of infected host to spread
- Payload may be destructive or disruptive

Virus lifecycle (supplement)

- Dormant phase (not present in every virus)
- Propagation
- Triggering
- Execution of payload

Virus types (supplement)

- File-infecting virus
- Macro virus
- Boot-sector virus
- Polymorphic or metamorphic virus

Computer worm (supplement)

- Self-contained program that propagates between systems
- Often exploits exposed services or social channels
- Can spread without attaching to a host program

Virus vs worm (supplement)

- Virus attaches to host code
- Worm propagates as a standalone program
- Both can carry malicious payloads
- Spread mechanisms and defenses differ

Malware defenses (supplement)

- Keep systems patched
- Use endpoint protection and least privilege
- Segment networks and back up data
- Educate users about untrusted attachments

Response to suspected infection (supplement)

- Isolate affected devices
- Preserve relevant logs and evidence
- Follow institutional incident-response procedure
- Restore from trusted backups after remediation

Case discussion

- A user opens an attachment and unusual outbound traffic begins
- What evidence would distinguish worm activity from other malware?
- What containment action should happen first?

Practice questions

- Explain salt and password-verifier storage
- Compare reactive and proactive password checking
- Differentiate a virus and a worm
- Describe layered malware defenses

Lecture Feedback



Please scan the QR code and share your lecture feedback.